INFORME DE AUDITORÍA DE SEGURIDAD — PENETRATION TEST WORDPRESS

Caso de estudio de portafolio — Sitio WordPress + WooCommerce

Objetivo	https://sitio-ejemplo.com (dominio anonimizado para portafolio)
Fecha	Junio 2026
Tipo de prueba	Caja negra (Black Box)
Autorización	Prueba realizada con autorización expresa del propietario del sitio
Clasificación	Caso de estudio — datos identificativos anonimizados

1. Resumen Ejecutivo

Se realizó una auditoría de seguridad de caja negra sobre un sitio WordPress con WooCommerce y plugins adicionales. El objetivo fue identificar vulnerabilidades explotables que pudieran comprometer la confidencialidad, integridad y disponibilidad del sistema.

Se identificaron 20 vulnerabilidades en total, incluyendo 4 críticas que permitirían a un atacante no autenticado crear cuentas de administrador, ejecutar inyecciones SQL y tomar control total del sitio.

🔴 **Crítico (4)**	**Acción inmediata requerida**
🟠 **Alto (8)**	**Corregir en menos de 7 días**
🟡 **Medio (5)**	**Corregir en menos de 30 días**
🟢 **Bajo/Info (3)**	**Corregir en menos de 90 días**

2. Hallazgos Críticos

H-01 — Creación arbitraria de administrador vía CSRF

CVE-2026-3589 (WooCommerce < 10.5.3). WooCommerce permitía crear usuarios administradores mediante una solicitud CSRF sin autenticación, otorgando control total del sitio y acceso a la base de clientes.

Remediación: actualizar WooCommerce a 10.5.3+ e implementar tokens CSRF en formularios de creación de usuarios.

H-02 — XML-RPC habilitado, fuerza bruta amplificada

El endpoint xmlrpc.php estaba activo y permitía hasta 1000 intentos de login en una sola solicitud HTTP (system.multicall), amplificando ataques de fuerza bruta y exponiendo el sitio a DDoS vía pingbacks.

Remediación: deshabilitar xmlrpc.php por completo vía .htaccess o un plugin de seguridad.

H-03 — Registro público de usuarios habilitado

El registro de nuevos usuarios estaba abierto al público, permitiendo crear cuentas con rol Subscriber o Contributor, combinable con otras vulnerabilidades para escalar privilegios.

Remediación: deshabilitar el registro público o exigir verificación por correo y CAPTCHA.

H-04 — Enumeración de usuarios no autenticada

El endpoint /wp-json/wp/v2/users exponía los nombres de usuario de todos los autores registrados sin autenticación, incluyendo varias cuentas de superadministrador, facilitando ataques dirigidos de fuerza bruta e ingeniería social.

Remediación: restringir el endpoint REST de usuarios.

3. Hallazgos Altos (resumen)

- H-05 — XSS almacenado en plugin de constructor de páginas (CVE-2026-6127), explotable por usuarios con rol Contributor.
- H-06 — Inyección SQL en WooCommerce explotable por rol Shop Manager, con acceso potencial a datos de clientes y contraseñas con hash.
- H-07 — Redirección abierta sin autenticación en plugin de integración con redes sociales, utilizable para phishing.
- H-08 — Exposición de datos de pedidos de otros clientes a través de la Store API, accesible por cualquier usuario registrado.

4. Hallazgos Medios y Bajos (resumen)

- readme.html y license.txt públicos, exponiendo la versión exacta del CMS.
- Header X-Powered-By revelando el panel de control del servidor.
- wp-cron.php accesible públicamente, utilizable para generar carga excesiva (DoS).
- Plugin de slider con divulgación de información para usuarios Subscriber+.
- Versión de WordPress expuesta en el feed RSS.
- Subdominios con respuestas diferenciadas que ameritan revisión adicional.

5. Cadena de Ataque Principal

La combinación de hallazgos permite, sin autenticación inicial: (1) enumerar usuarios vía REST API, (2) registrarse públicamente, (3) inyectar XSS como Contributor, (4) robar la sesión de un administrador, (5) crear un usuario administrador vía CSRF, y (6) exfiltrar la base de datos de clientes mediante inyección SQL.

6. Plan de Remediación Priorizado

- Inmediato: actualizar WooCommerce, deshabilitar xmlrpc.php, deshabilitar registro público, restringir el endpoint REST de usuarios.
- < 7 días: actualizar el plugin de constructor de páginas, el de integración social y el de slider.
- < 30 días: deshabilitar WP-Cron público, ocultar header X-Powered-By, eliminar readme.html/license.txt.
- < 90 días: ocultar versión de WordPress en RSS, auditar y limpiar subdominios sin uso.

7. Conclusión

El sitio presentó un perfil de riesgo CRÍTICO: la combinación de vulnerabilidades permitía a un atacante externo, sin credenciales previas, tomar control completo del sitio siguiendo una cadena de ataque lógica y reproducible. Se recomendó implementar las acciones inmediatas en 24-48 horas, un WAF activo, autenticación de dos factores para administradores y un proceso regular de actualización de plugins. Se sugirió una auditoría de seguimiento 30 días después de la remediación.

— Fin del informe —